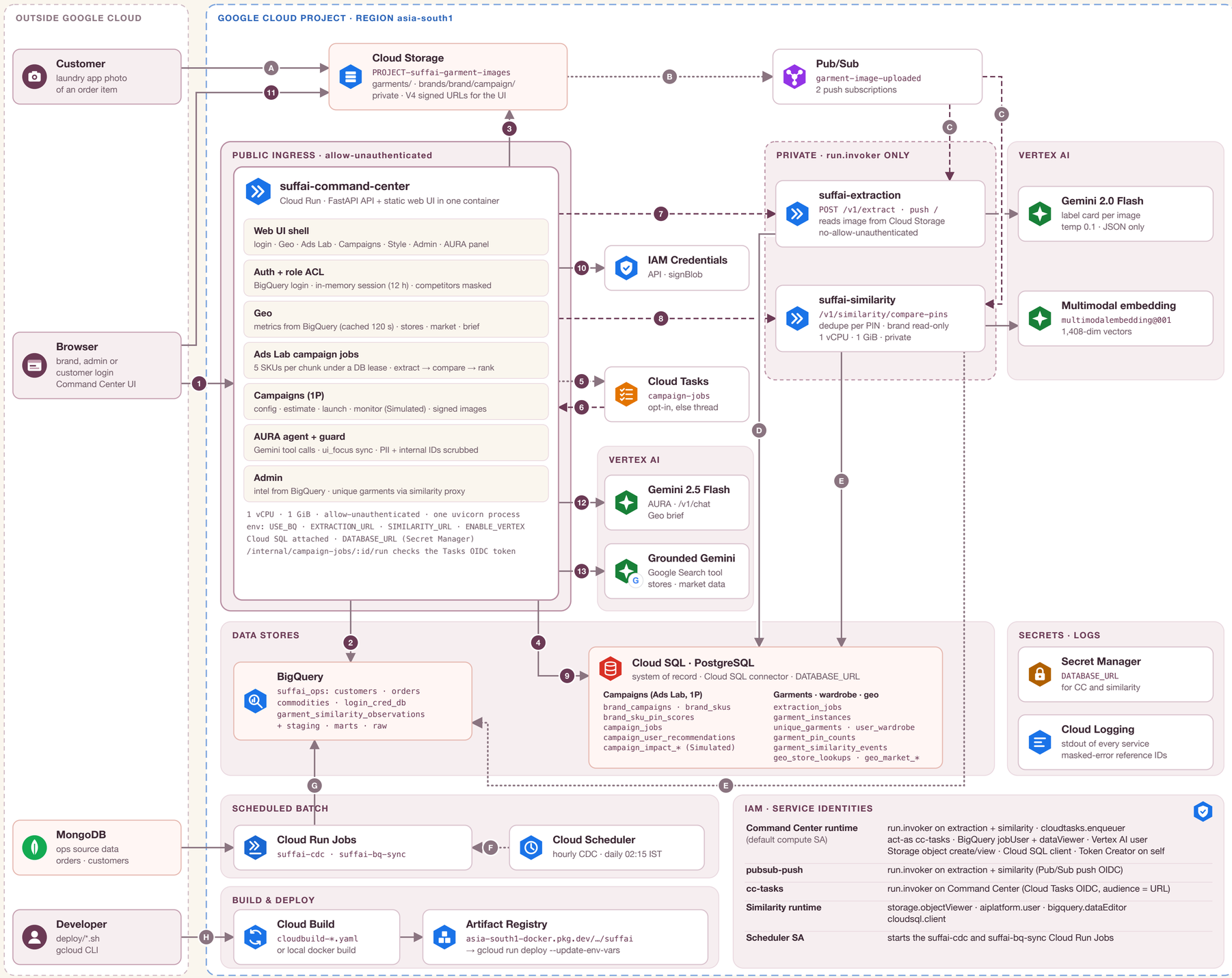
SuffAI Command Center · Engineering Review Diagram

As deployed on Google Cloud (region asia-south1): trust boundaries, service identities, how every hop is authenticated, and the numbered end-to-end flow · reviewed 18 Oct 2026



END-TO-END FLOW

Brand journey (numbered on the diagram)

1. Sign in over HTTPS: POST /v1/auth/login returns a session token, sent as X-Session-Token
2. Password hash checked in BigQuery login_cred_db; Geo metrics read from suffai_ops (cached 120 s)
3. Ads Lab SKU images written to Cloud Storage under brands/brand/campaign/
4. Campaign, SKU and job rows created in Cloud SQL (processing · pending · queued)
5. Job chunk enqueued on Cloud Tasks campaign-jobs (or run in a thread if Tasks isn't set up)
6. Cloud Tasks calls /internal/campaign-jobs/:id/run with an OIDC token minted as cc-tasks
7. Extract attributes: POST /v1/extract with a Google ID token; Gemini 2.0 Flash label card
8. Compare with PIN wardrobes: POST /v1/similarity/compare-pins with an ID token; top 5 per PIN
9. Rank (55% visual · 15% frequency · 30% attribute fit); save scores and per-customer picks
10. Campaigns tab: image URLs signed (V4) through the IAM Credentials API (signBlob)
11. Browser loads SKU images straight from Cloud Storage with the signed URLs
12. AURA: /v1/agent/chat with ui_focus; ownership checked, then Gemini 2.5 Flash tool calls
13. Geo stores and market data: Gemini 2.5 Flash + Google Search grounding, cached 7 days

Customer photos, scheduled loads and deploys (lettered)

- A Customer garment photo stored in Cloud Storage under garments/
- B Upload event published to Pub/Sub topic garment-image-uploaded
- C Two push subscriptions call extraction and similarity with an OIDC token (pubsub-push)
- D Extraction writes the label card and job state to Cloud SQL (all fields ≥ 0.90 auto-accepted)
- E Similarity counts each garment once per PIN in Cloud SQL and copies observations to BigQuery
- F Cloud Scheduler starts Cloud Run Jobs: suffai-cdc hourly, suffai-bq-sync daily at 02:15 IST
- G Jobs read MongoDB and load suffai_ops, staging and marts into BigQuery
- H Cloud Build image → Artifact Registry repo suffai → gcloud run deploy --update-env-vars

CONTROLS IN PLACE

- Private services accept only Google-signed tokens (ID tokens, Pub/Sub push and Cloud Tasks OIDC)
- Every campaign and job read checks brand ownership; brand logins see other brands as Competitors
- AURA guard strips customer PII and internal IDs before Gemini; its on-screen focus carries no IDs
- Users see masked errors with a reference ID; the full error goes to Cloud Logging
- The plaintext credentials CSV is kept out of the image by .dockerignore

RELIABILITY

- Cloud Tasks retries a chunk up to 10 times (10–300 s backoff); a job stalled 180 s is re-dispatched
- Each chunk runs under a DB lease, so a retried or duplicate task can't process the same SKUs twice
- Extraction is idempotent on the Pub/Sub message ID; bad payloads are acked, other errors retried
- Geo store and market lookups are cached 7 days in Cloud SQL; metrics are cached 120 s per instance

ENGINEERING REVIEW FINDINGS

- **HIGH** Sessions, AURA state and staged uploads live in one instance's memory. A second Cloud Run instance signs users out at random: set --max-instances=1 now, move sessions to Cloud SQL or Memorystore.
- **HIGH** Passwords are unsalted SHA-256 hashes (BigQuery login_cred_db and the CSV fallback in the image). Move to bcrypt or argon2, or to Identity Platform.
- **MED** Signed image URLs need Token Creator on the runtime account itself and iamcredentials.googleapis.com enabled; otherwise Campaigns shows drawn placeholders.
- **MED** Campaign jobs run in a thread unless setup_cloud_tasks.sh was run. Cloud Run CPU is request-only, so those jobs mostly advance while the UI polls.
- **MED** Services fall back to the default compute account, which often has Editor. Give each service its own least-privilege account.
- **LOW** deploy_command_center.sh writes DATABASE_URL as a plain env var (prefer --set-secrets), and CORS_ORIGINS=* is set on the public service (restrict it to its own URL).

DEPLOYMENT FACTS

- Cloud Run: suffai-command-center (public) · suffai-extraction, suffai-similarity (private)
- Cloud Run Jobs: suffai-cdc and suffai-bq-sync · all images in Artifact Registry repo suffai
- Retired: suffai-api (do not recreate)

GCP SERVICES USED

Cloud Run · Cloud Run Jobs · Cloud Storage · Pub/Sub · Cloud Tasks · Cloud Scheduler · Vertex AI · Google Search grounding · Cloud SQL · BigQuery · IAM + IAM Credentials · Secret Manager · Cloud Logging · Cloud Build · Artifact Registry

LEGEND

request or data read / write · service call with a Google ID token or OIDC token · async: queue, push event, schedule or copy · 1 brand journey step · A pipeline or deploy step · Google Cloud project · outside Google Cloud · public ingress · private (run.invoker only)

Source: deploy/*.sh, Dockerfile.command_center, command_center/*.py, worker/, similarity/ · PROJECT stands for the GCP project ID · campaign impact metrics are simulated and labelled Simulated in the UI · brand logins see competitors masked · no customer PII is sent to the AI